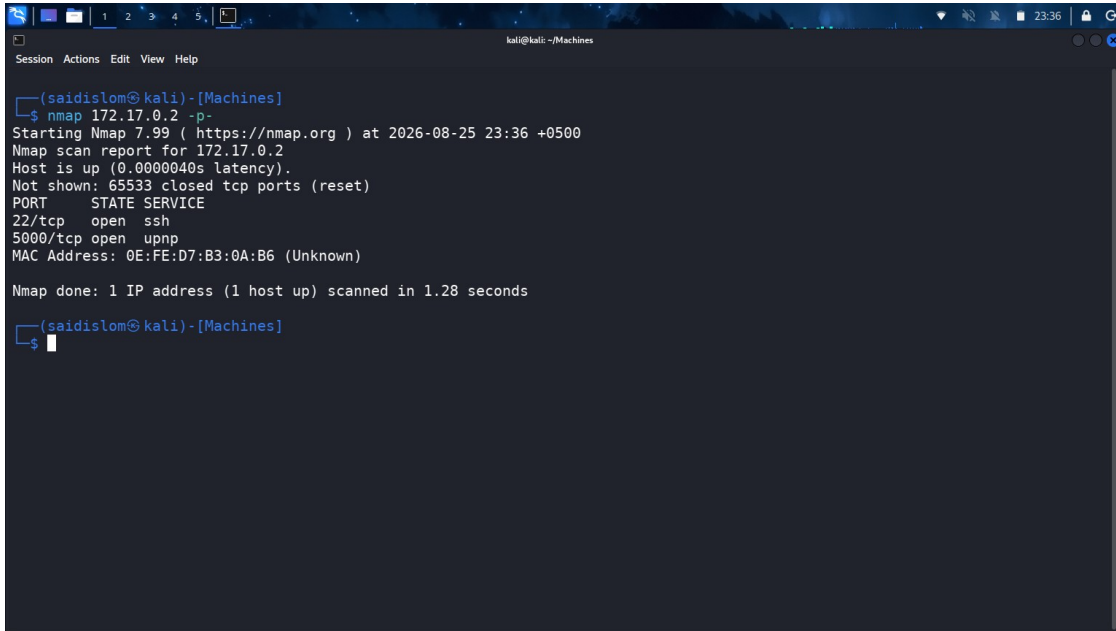


Aidor - Writeup

1. Reconnaissance

IP - 172.17.0.2

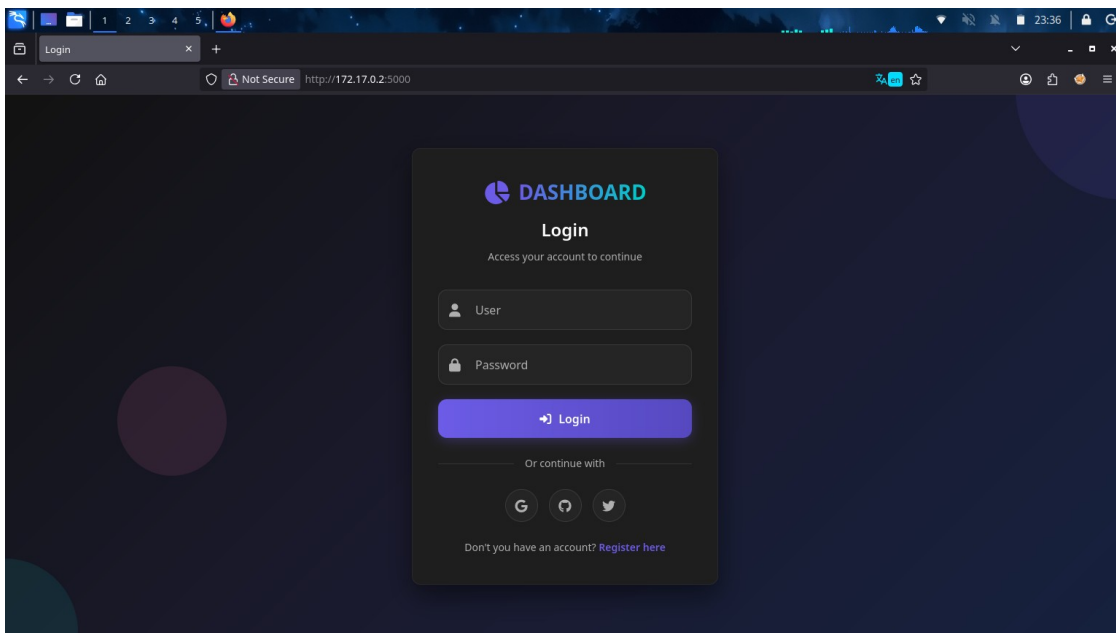


```
(saidislom@kali)-[Machines]
$ nmap 172.17.0.2 -p-
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-25 23:36 +0500
Nmap scan report for 172.17.0.2
Host is up (0.0000040s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
5000/tcp  open  upnp
MAC Address: 0E:FE:D7:B3:0A:B6 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 1.28 seconds

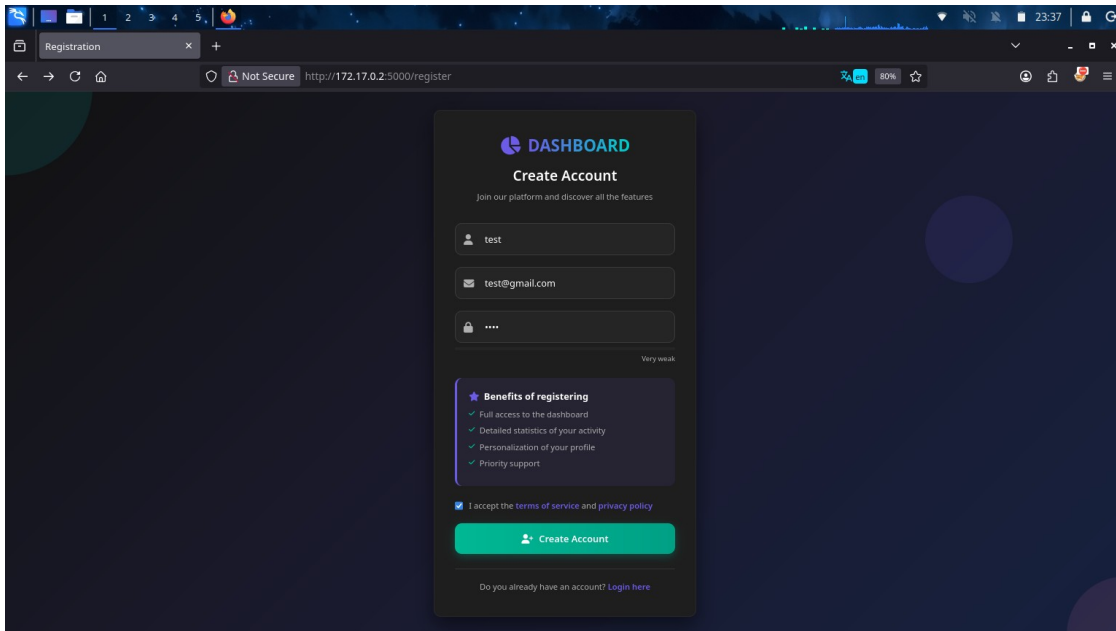
(saidislom@kali)-[Machines]
$
```

nmap orqali to'liq port skanerlash (-p-) qildik: 22/tcp (ssh) va 5000/tcp (upnp - aslida web ilova) portlari ochiq ekan.

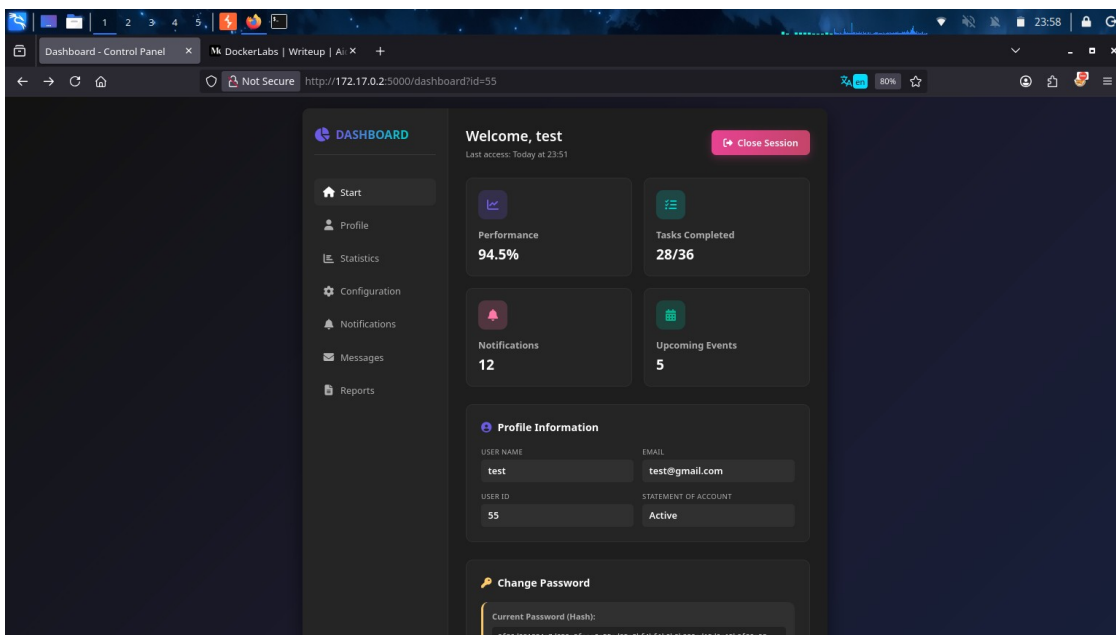


5000-portda "DASHBOARD" nomli login sahifasi turibdi. Pastida "Register here" havolasi ham bor edi.

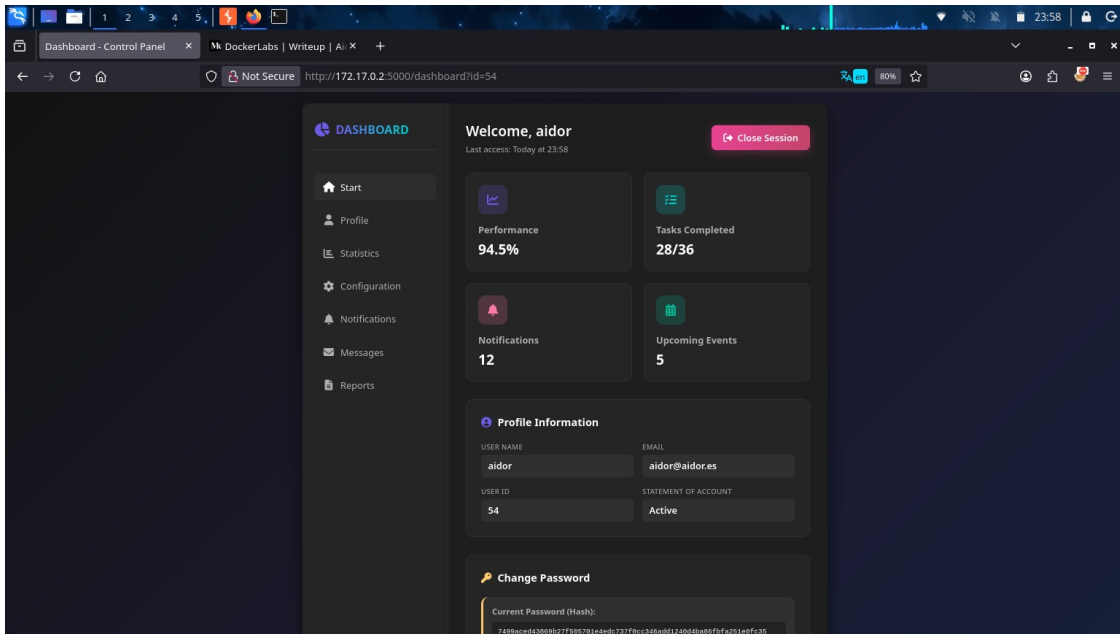
2. Ro'yxatdan o'tish va IDOR zaifligini topish



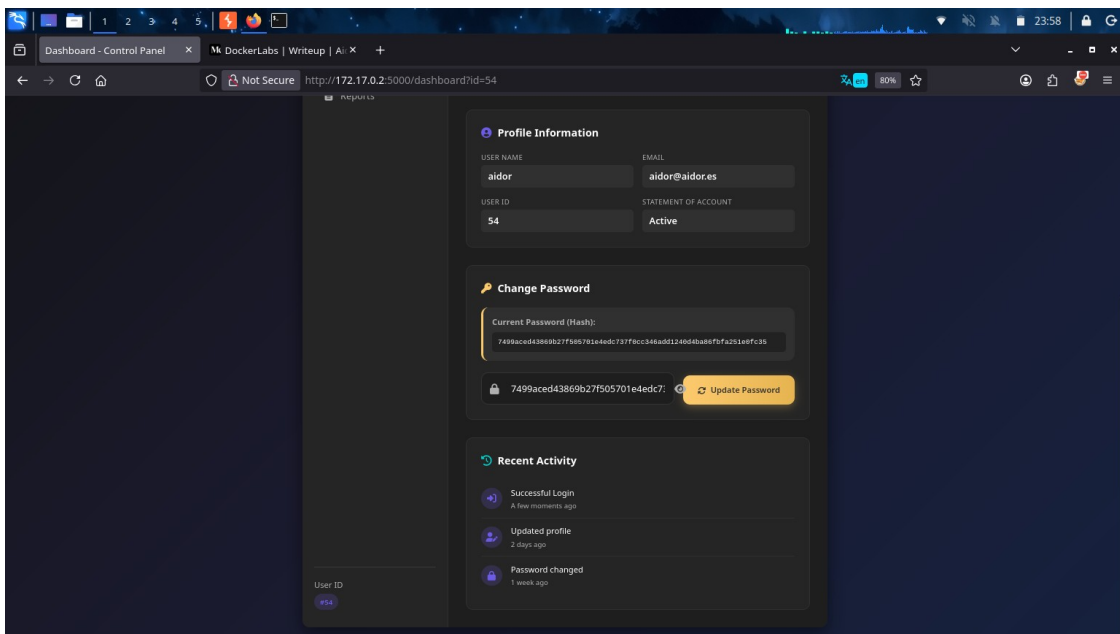
Ro'yxatdan o'tish (Create Account) sahifasida test / test@gmail.com / oddiy parol bilan yangi hisob yaratdik.



Yaratilgan hisob bilan tizimga kirdik. Dashboard sahifasi /dashboard?id=55 manzilida ochildi - bu bizning user ID'imiz (test, id=55) ekan. Parol hash ko'rinishida (Change Password bo'limida) ko'rsatilgan edi.

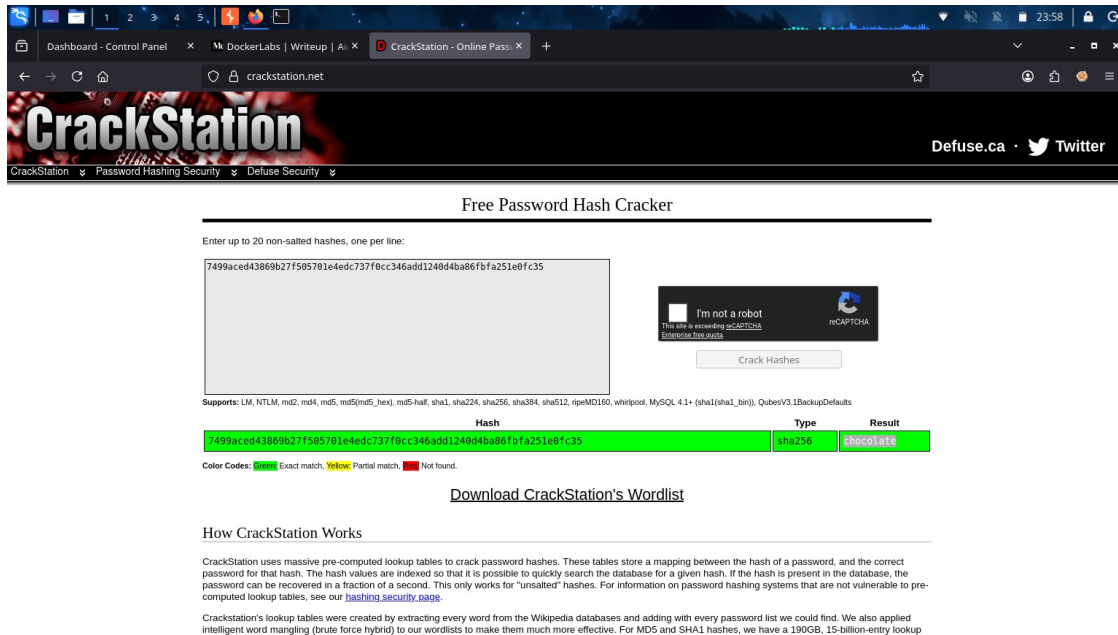


URL'dagi id parametrini 55'dan 54'ga o'zgartirib ko'rdik (IDOR - Insecure Direct Object Reference). Natijada tizim bizni tekshirmasdan boshqa foydalanuvchi - aidor (id=54) nomidagi Dashboard sahifasini ko'rsatib berdi.



aidor foydalanuvchisining Dashboard sahifasini pastga aylantirib, Change Password bo'limida uning parol hashini (7499aced43869b27f505701e4edc737f0cc346add1240d4ba86fbfa251e0fc35) ko'rdik - IDOR orqali boshqa userning maxfiy ma'lumotiga ega bo'ldik.

3. Hash'ni krek qilish va SSH orqali kirish



Free Password Hash Cracker

Enter up to 20 non-salted hashes, one per line:

7499aced43869b27f505701e4edc737f0cc346add1248d4b86fbfa251e0fc35

I'm not a robot

Crack Hashes

Supports: LM, NTLM, md2, md4, md5, md5(md5_hex), md5-half, sha1, sha224, sha256, sha384, sha512, ripeMD160, whirlpool, MySQL 4.1+ (sha1(sha1_bin)), QubesV3.1BackupDefaults

Hash	Type	Result
7499aced43869b27f505701e4edc737f0cc346add1248d4b86fbfa251e0fc35	sha256	chocolate

Color Codes: Exact match, Partial match, Not found

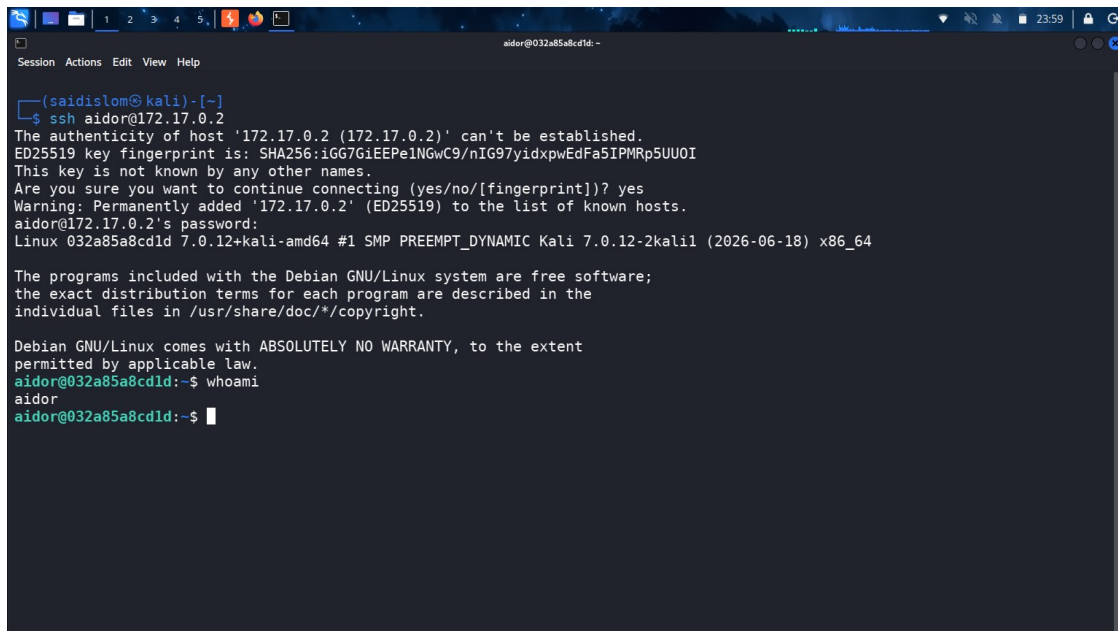
[Download CrackStation's Wordlist](#)

How CrackStation Works

CrackStation uses massive pre-computed lookup tables to crack password hashes. These tables store a mapping between the hash of a password, and the correct password for that hash. The hash values are indexed so that it is possible to quickly search the database for a given hash. If the hash is present in the database, the password can be recovered in a fraction of a second. This only works for "unsalted" hashes. For information on password hashing systems that are not vulnerable to pre-computed lookup tables, see our [hashing security page](#).

CrackStation's lookup tables were created by extracting every word from the Wikipedia databases and adding with every password list we could find. We also applied intelligent word mangling (brute force hybrid) to our wordlists to make them much more effective. For MD5 and SHA1 hashes, we have a 100GB, 15-billion-entry lookup

Topilgan sha256 hashni CrackStation onlayn xizmatiga kiritib krek qildik. Natijada aidor foydalanuvchisining paroli chocolate ekanini bilib oldik.



```
aidor@032a85a8cd1d: ~  
Session Actions Edit View Help  
  
(saidislom@kali)-[~]  
$ ssh aidor@172.17.0.2  
The authenticity of host '172.17.0.2 (172.17.0.2)' can't be established.  
ED25519 key fingerprint is: SHA256:IG67GiEEPe1NGwC9/nIG97yidxpWEdFa5IPMRp5UUOI  
This key is not known by any other names.  
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes  
Warning: Permanently added '172.17.0.2' (ED25519) to the list of known hosts.  
aidor@172.17.0.2's password:  
Linux 032a85a8cd1d 7.0.12+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 7.0.12-2kali1 (2026-06-18) x86_64  
  
The programs included with the Debian GNU/Linux system are free software;  
the exact distribution terms for each program are described in the  
individual files in /usr/share/doc/*/copyright.  
  
Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent  
permitted by applicable law.  
aidor@032a85a8cd1d:~$ whoami  
aidor  
aidor@032a85a8cd1d:~$
```

Topilgan aidor:chocolate ma'lumotlari bilan SSH orqali serverga kirdik. whoami buyrug'i aidor useri nomidan shell olganimizni tasdiqladi.

4. Privilege Escalation - manba kodidan root parolini topish

```
aidor@032a85a8cd1d:/home$ cat app.py | grep root
# ('root', 'aa87ddc5b4c24406d26ddad771ef44b0', 'admin@example.com')
aidor@032a85a8cd1d:/home$ ls -la
total 56
drwxr-xr-x 1 root root 4096 Aug 25 18:51 .
drwxr-xr-x 1 root root 4096 Aug 25 18:35 ..
drwx----- 1 aidor aidor 4096 Aug 25 19:00 aidor
-rw-r--r-- 1 root root 4862 Nov 17 2025 app.py
-rw-r--r-- 1 root root 24576 Aug 25 18:51 database.db
drwxr-xr-x 2 root root 4096 Nov 17 2025 templates
aidor@032a85a8cd1d:/home$
```

aidor useri sifatida ilova manba kodini (app.py) tekshirdik. cat app.py | grep root buyrug'i orqali kod ichida qattiq yozilgan (hardcoded) root foydalanuvchisining ma'lumotlarini topdik: ('root', 'aa87ddc5b4c24406d26ddad771ef44b0', 'admin@example.com') - bu yerda root uchun md5 hash ko'rinishidagi parol bor edi.

The screenshot shows the CrackStation website, a free password hash cracker. The interface includes a text input field for hashes, a reCAPTCHA verification step, and a "Crack Hashes" button. Below the input field, a table displays the results of the hash cracking process.

Hash	Type	Result
aa87ddc5b4c24406d26ddad771ef44b0	md5	estrella

Color Codes: ■ Exact match, ■ Partial match, ■ Not found.

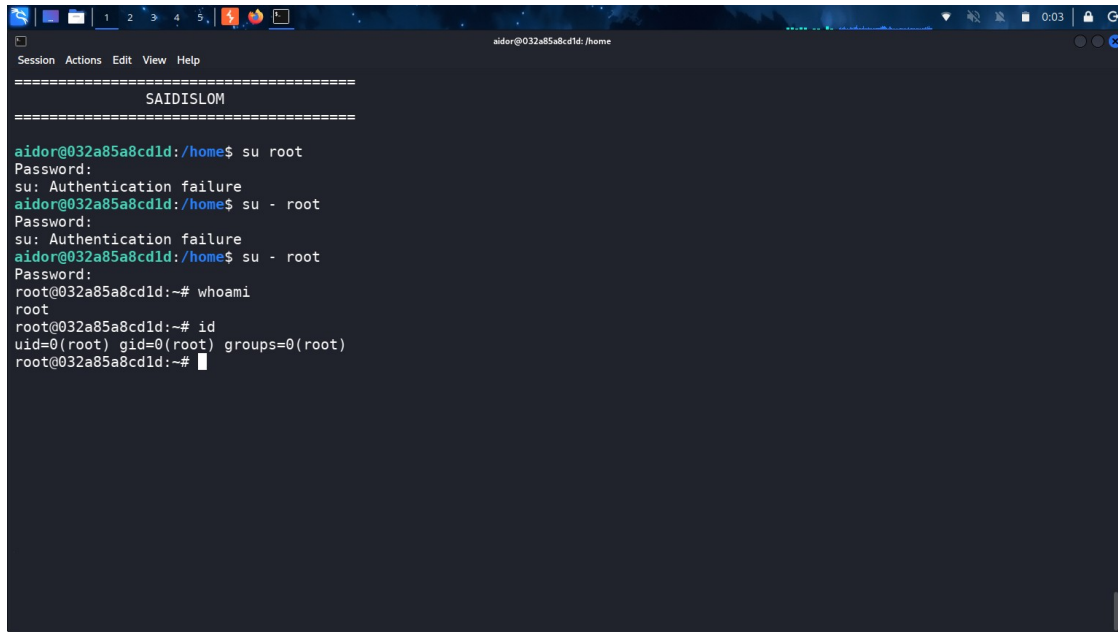
[Download CrackStation's Wordlist](#)

How CrackStation Works

CrackStation uses massive pre-computed lookup tables to crack password hashes. These tables store a mapping between the hash of a password, and the correct password for that hash. The hash values are indexed so that it is possible to quickly search the database for a given hash. If the hash is present in the database, the password can be recovered in a fraction of a second. This only works for "unsalted" hashes. For information on password hashing systems that are not vulnerable to pre-computed lookup tables, see our [hashing security page](#).

Crackstation's lookup tables were created by extracting every word from the Wikipedia databases and adding with every password list we could find. We also applied intelligent word mangling (brute force hybrid) to our wordlists to make them much more effective. For MD5 and SHA1 hashes, we have a 190GB, 15-billion-entry lookup

Topilgan md5 hashni CrackStation orqali krek qildik. Natijada root foydalanuvchisining paroli estrella ekanini aniqladik.



```
aidor@032a85a8cd1d: /home
=====
SAIDISL0M
=====

aidor@032a85a8cd1d:/home$ su root
Password:
su: Authentication failure
aidor@032a85a8cd1d:/home$ su - root
Password:
su: Authentication failure
aidor@032a85a8cd1d:/home$ su - root
Password:
root@032a85a8cd1d:~# whoami
root
root@032a85a8cd1d:~# id
uid=0(root) gid=0(root) groups=0(root)
root@032a85a8cd1d:~#
```

su - root buyrug'i orqali topilgan estrella paroli bilan root huquqiga o'tdik. whoami va id buyruqlari uid=0(root) - ya'ni to'liq root huquqiga chiqqanimizni tasdiqladi.

Xulosa:

Ushbu mashinada zaifliklar zanjiri quyidagicha bo'ldi: nmap bilan portlarni topish → web ilovada oddiy user sifatida ro'yxatdan o'tib tizimga kirish → dashboard sahifasidagi id parametrini o'zgartirib IDOR zaifligi orqali boshqa foydalanuvchi (aidor)ning parol hashini olish → hashni CrackStation orqali krek qilib aidor:chocolate ma'lumotlarini topish → SSH orqali aidor sifatida serverga kirish → ilova manba kodi (app.py) ichidan root foydalanuvchisining qattiq yozilgan (hardcoded) md5 hashini topish → hashni krek qilib root:estrella parolini olish → su - root orqali to'liq root huquqiga chiqish.

root huquqi olindi.